

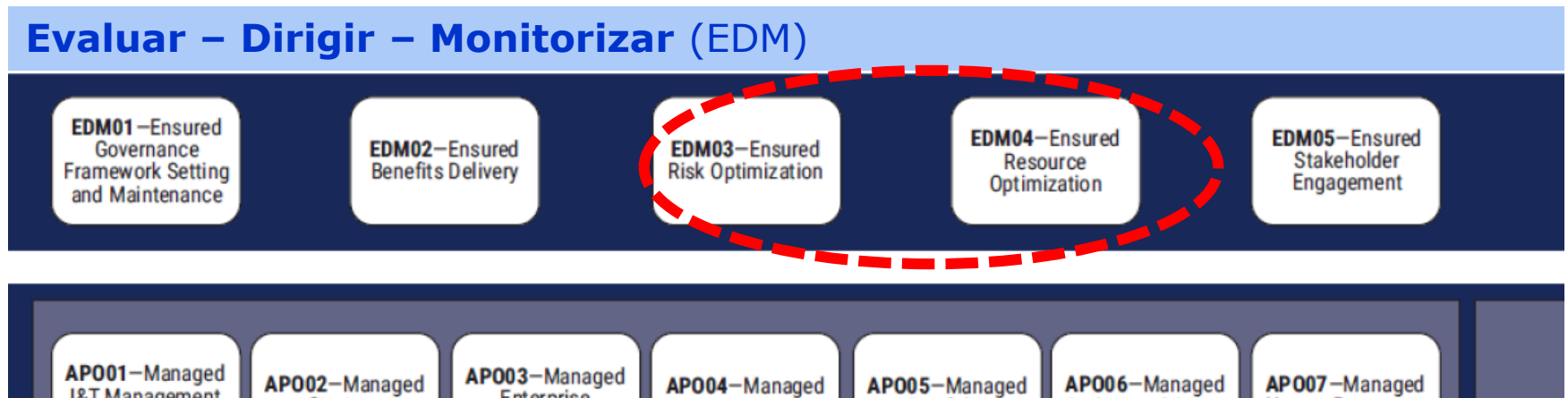
Gestión de Riesgos

Unidad 2: Administración de Recursos en Áreas de TI

Administración de Recursos en Áreas de TI

Cobit 2019

El Gobierno de TI se encarga de evaluar, dirigir y monitorizar (EDM), en función de de 5 objetivos:



En esta unidad nos enfocaremos en 2 de ellos:

- Asegurar la Optimización del **RIESGO**
- Asegurar la Optimización de los **RECURSOS**

Administración de Recursos en Áreas de TI

Comprender la **Gestión de RIESGOS** de TI para cumplir con el objetivo del Gobierno de TI:

Optimizar los RIESGOS



Comprender la **Gestión de SERVICIOS** de TI para cumplir con el objetivo de Gobierno de TI:

Optimizar los RECURSOS



En ambos casos debemos tener el **foco** en mantener la **continuidad de los procesos críticos y claves** de la organización

Gestión de Riesgos

Seguridad de la información

Definición

Seguridad de la información

Es el proceso de **planear, organizar, coordinar, dirigir y controlar** las actividades relacionadas a asegurar la información de una organización en todas sus dimensiones:

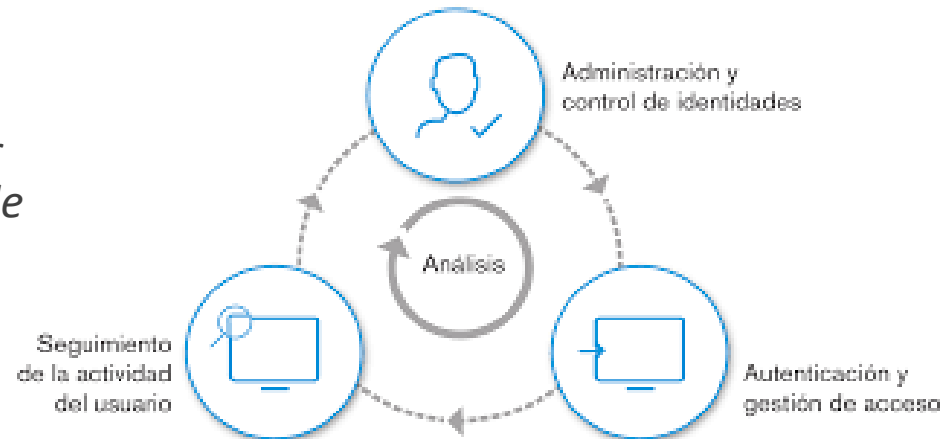
- integridad,
- confidencialidad y
- disponibilidad

Y prepararse para las **contingencias** que puedan ocurrir en un grado acorde a la **criticidad de la Misión de Negocio**

Seguridad de la información

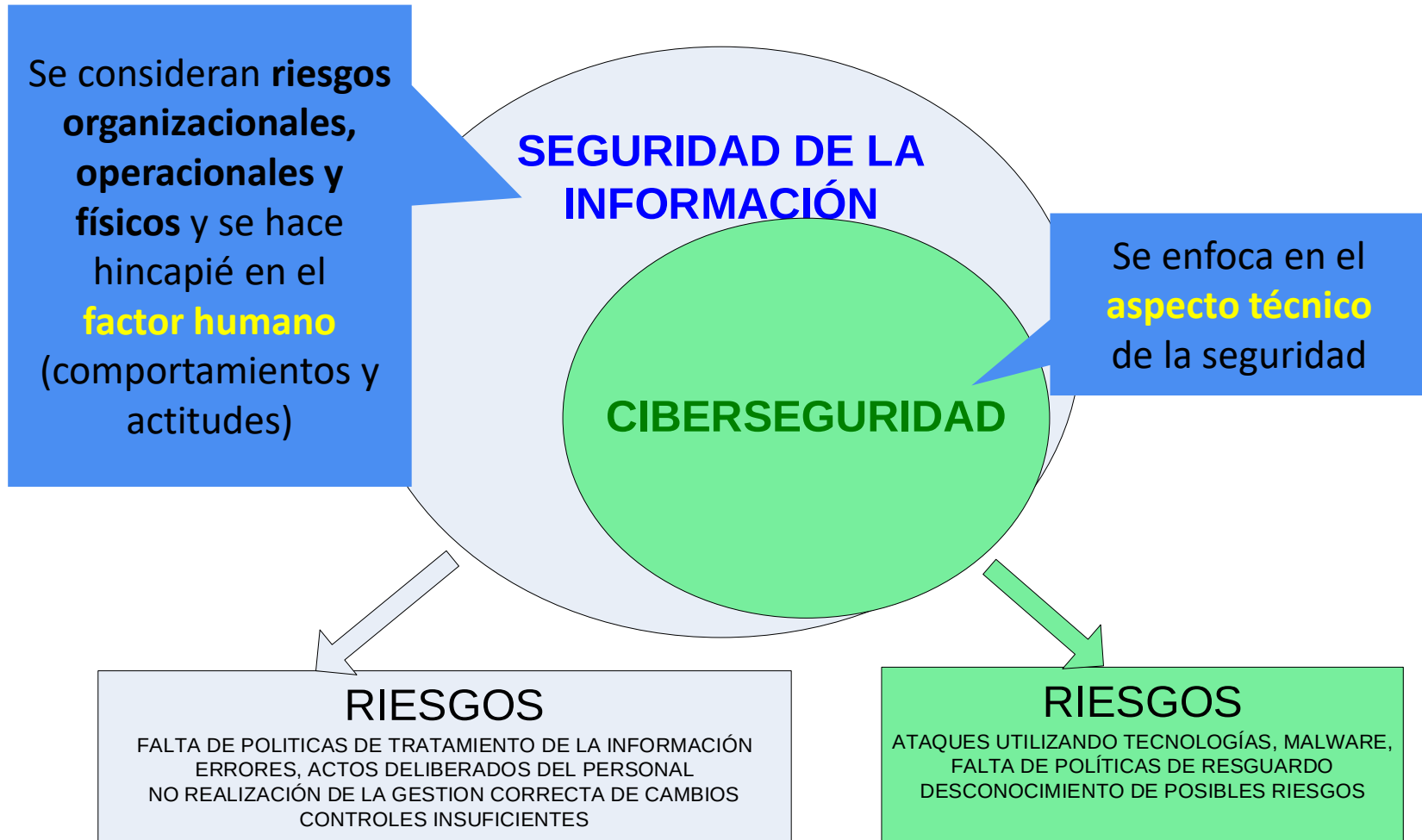
Dimensiones

- **Confidencialidad:** garantizar la **privacidad** de la información y de su tratamiento, para prevenir su divulgación no autorizada cuando está almacenada o en tránsito.



- **Disponibilidad:** garantizar que los recursos (información, sistemas, almacenamiento) sean **accesibles y utilizables** por los usuarios (o procesos) autorizados cuando estos lo requieran.

Seguridad de la información

Seguridad y Ciberseguridad

Seguridad de la información

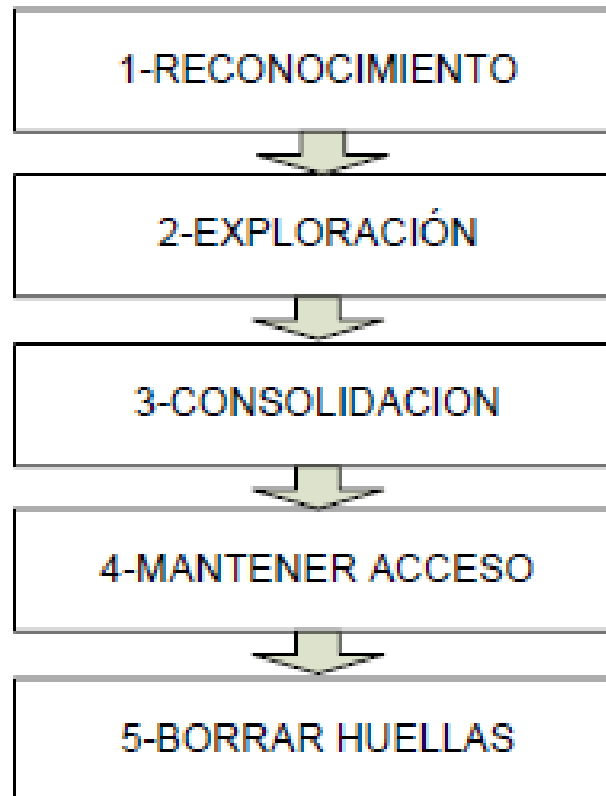
Los mitos de la ciberseguridad

- ✓ El ataque de **phishing** solo es hacia **grandes empresas** u organizaciones.
- ✓ El software **antivirus** es **suficiente para protegerte**
- ✓ No **puedo hacer nada** para **protegerme de los ataques** y si me atacan no hay nada que pueda hacer
- ✓ Las **amenazas** de ciberseguridad siempre provienen de **agentes externos**
- ✓ La **suplantación de identidad** digital afecta únicamente a **personas famosas**
- ✓ Si un sitio web tiene el **candadito** cerrado y/o verde, es **100% seguro**.
- ✓ Los **hackers** son personas **malintencionadas**



.... Y muchos más

Etapas de un ciberataque



Mitigación de ataques informáticos

Las organizaciones implementan **centros de operaciones de seguridad (SOC)** o **contratan personal** que realice monitoreo y responda a los posibles incidentes.

HERRAMIENTAS

- **IDS: Sistema de **detección** de Intrusiones**
dispositivo de monitoreo pasivo que detecta amenazas potenciales y genera alertas.
- **IPS: Sistema de **prevención** de intrusiones**
para encontrar de actividad maliciosa e intentar detenerla, monitorizando el tráfico en la red, de forma continua.

Gestión de Riesgos

Buenas prácticas

Buenas prácticas

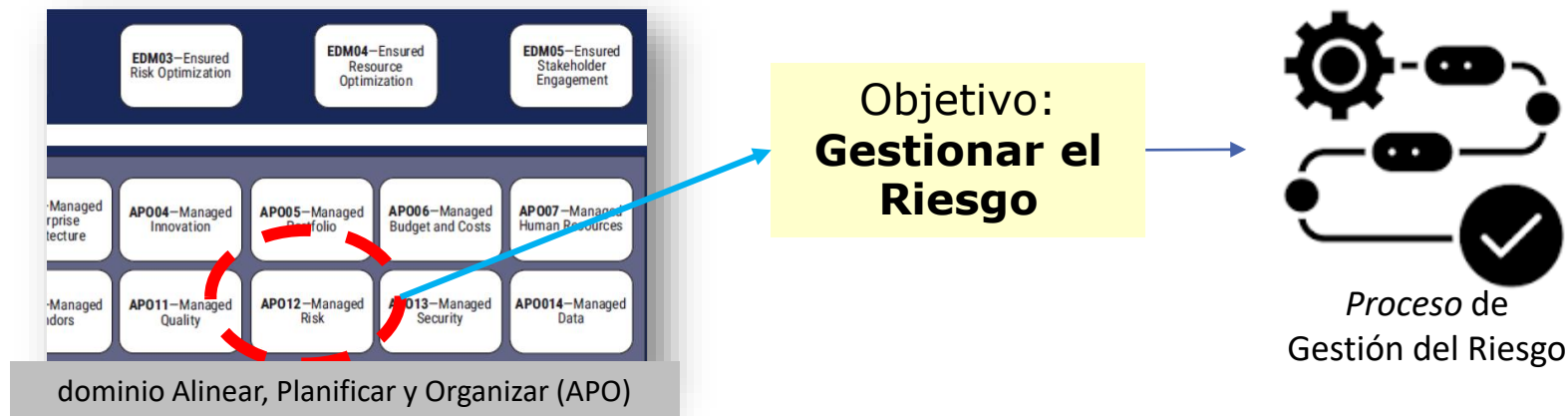
Existen muchos estándares, guías de buenas prácticas y marcos de trabajo dedicados a diferentes aspectos de la seguridad de la información.

Nos interesan:

1. Las dedicadas a establecer metodologías referidas al **proceso** en sí y a la **identificación de riesgos** y su tratamiento
2. Las dedicadas a establecer mecanismos para **actuar ante la materialización de un riesgo**: contingencia, recuperación y continuidad de las operaciones del negocio.

Buenas prácticas

COBIT 2019



ISO 31000: 2018 Establece *principios y guías* genéricas para la Gestión de Riesgos

MAGERIT V3

(Metodología de Análisis y Gestión de Riesgos de Sist. de Información)

Método formal para *investigar riesgos* de los Sistemas de Información y para *recomendar las medidas* que deberían adoptarse para **controlarlos**.

ISO 27000

27001:2022
27002:2022
27005:2022

Marco para el Sist. De Gestión de Seguridad de la Inform. (SGSI)

Normas certificables sobre Seguridad de la información, ciberseguridad y protección de la privacidad

Buenas prácticas

Controles de seguridad de la información

ISO 27002: Controles



Buenas prácticas

*Controles de seguridad de la información***ISO 27002: Atributos de un control**

Buenas prácticas

Controles de seguridad de la información

ISO 27002: Ejemplo Control de Accesos

Medios para garantizar que el **acceso físico y lógico** a los activos esté **autorizado y restringido** en función de requisitos de seguridad empresarial y de la información.

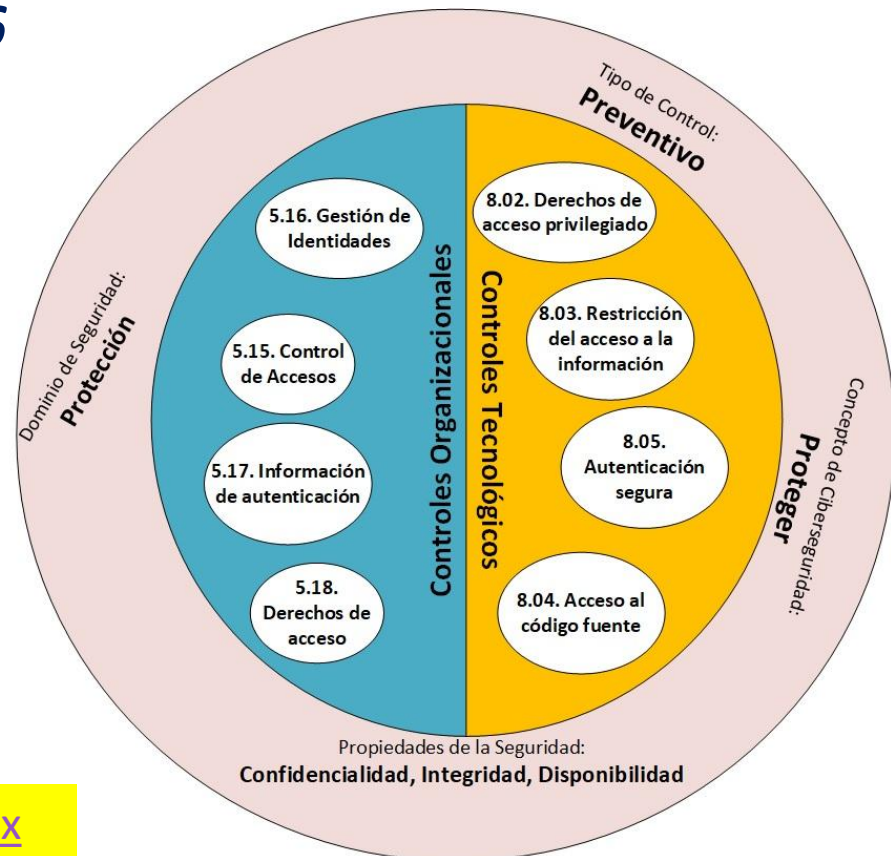


Capacidades Operacionales:
Gestión de Identidades y Accesos

Buenas prácticas

*Controles de seguridad de la información***ISO 27002: Ejemplo Control de Accesos**

*Utilizando la planilla de **Anexo 6**
Controles ISO 27002:2022
se obtienen los siguientes
controles:*



[ASI-2-Anexo6 ISO 27002 Controles.xlsx](#)

Gestión de Riesgos

El proceso de Gestión de Riesgos

El proceso de Gestión de Riesgos

COBIT 2019

EL PROCESO

1. Recopilar datos

2. Analizar el riesgo

- a. Hacer **Inventario de riesgos conocidos**
- b. **Comunicar** internamente el riesgo
- c. Definir **como gestionar** el riesgo

3. Responder ante el riesgo

El proceso de Gestión de Riesgos

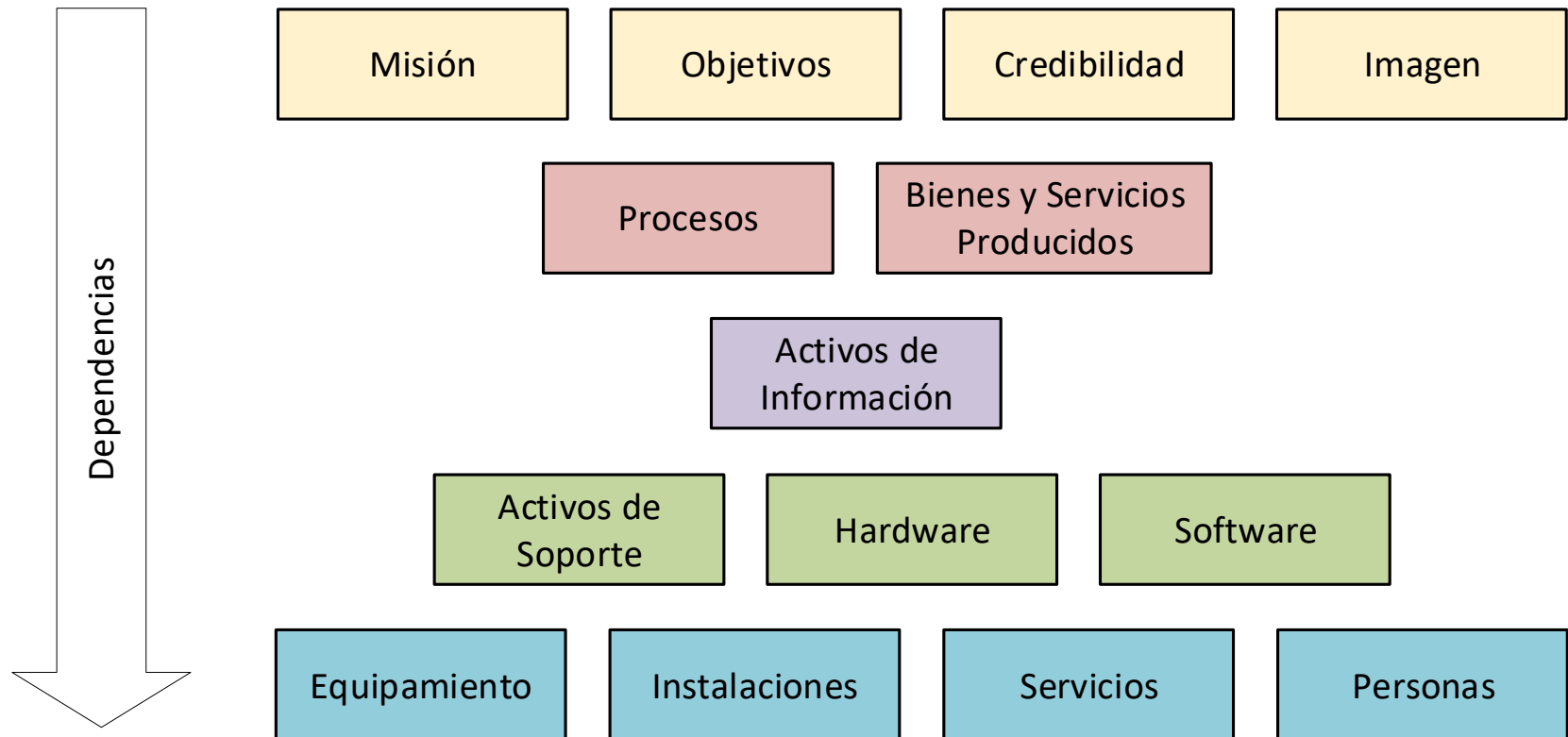
1 - Recopilar Datos

IDENTIFICACIÓN DE ACTIVOS

Los **ACTIVOS** son los **recursos necesarios** para que una organización o alguno de sus procesos **funcione correctamente y alcance sus objetivos.**

Un **inventario de activos** permite la identificación de activos y componentes críticos y es esencial para **conocer qué debe protegerse**

El proceso de Gestión de Riesgos

*1 - Recopilar Datos***IDENTIFICACIÓN DE ACTIVOS - Dependencias entre Activos**

1 - Recopilar Datos

Actividad

Circuito Toma Exámenes UTN

IDENTIFICACIÓN DE ACTIVOS - Inventario

*Trabajemos sobre el proceso de **Toma de exámenes en UTN***

TAREA: Identificar **activos** y clasificarlos en:

1. De Información
2. De Software
3. De Hardware
4. De Soporte
5. Equipamiento
6. Instalaciones
7. Servicios
8. Personas

1 - Recopilar Datos

ALTERNATIVA DE SOLUCION

IDENTIFICACIÓN DE ACTIVOS - Inventario

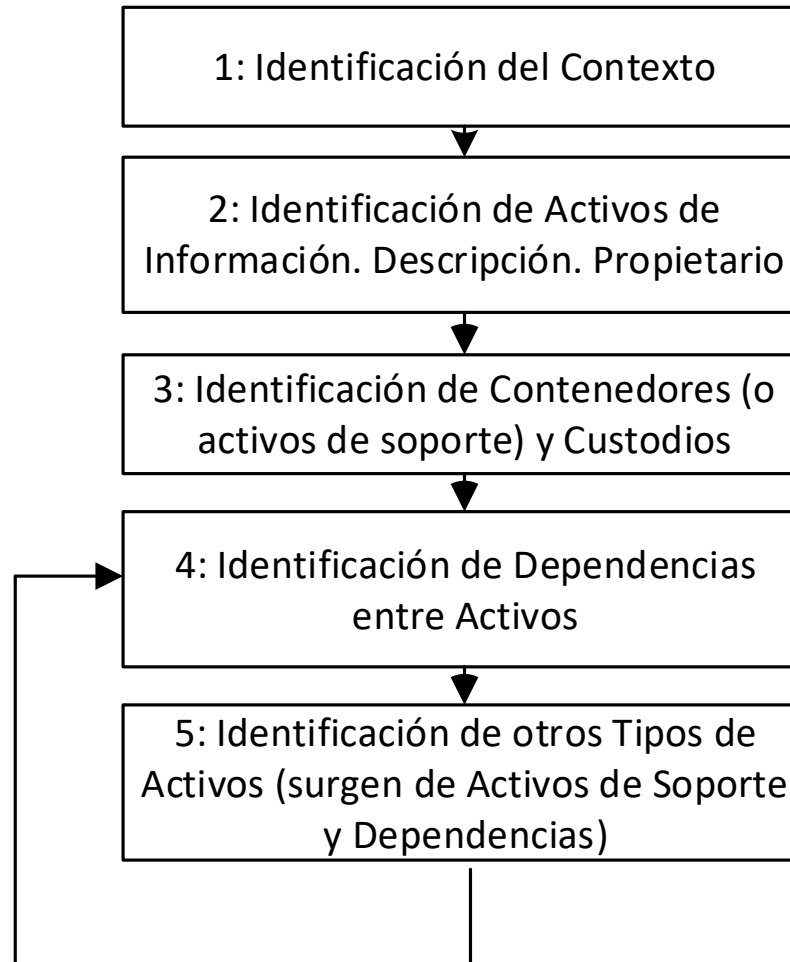
*Algunos activos del Proceso de **Toma de exámenes en UTN***

1. **Información** → Acta examen, planificación cátedra, Ternas exámenes
2. **Software** → Sysacad, MS SQL server
3. **Hardware** → Servidor, Cableado red
4. **Soporte** → BD Sysacad, cajas con sobres de examen
5. **Equipamiento** → UPS, impresoras de Legajos y Actas
6. **Instalaciones** → Oficina Bedelía, Oficinas departamento de carrera
7. **Servicios** → internet, electricidad
8. **Personas** → Bedel, Profesor, Alumno, Director departamento

El proceso de Gestión de Riesgos

1 - *Recopilar Datos*

IDENTIFICACIÓN DE ACTIVOS - Inventario



El proceso de Gestión de Riesgos

*1 - Recopilar Datos***IDENTIFICACIÓN DE ACTIVOS - Inventario - Atributos**

- **Identificador**
- **Nombre + Descripción**
- **Propietario** *El que tiene la responsabilidad de viabilidad y supervivencia del activo*
- **Contenedores o Soportes del Activo de Información** *Para diferenciar el activo de la forma en que se almacena, procesa y distribuye.*
- **Custodio** *Responsable de la viabilidad y la capacidad de supervivencia del activo*
- **Origen** *identifica quién es el que tiene la potestad de generar el Activo*
- **Acceso al activo**
 - ✓ **Público**
 - ✓ **Compartido** *en grupos o personas no pertenecientes a la organización*
 - ✓ **Reservado** *Sólo empleados de la organización*
 - ✓ **Confidencial** *Lista específica de personas*
- **Dependencias** *activos a partir de los cuales la materialización de una amenaza tenga como consecuencia efectos en la seguridad del activo*

1 - Recopilar Datos

Actividad

IDENTIFICACIÓN DE ACTIVOS - Inventario

*Sigamos con el proceso de **Toma de exámenes en UTN***

TAREA:

Tomar un activo de cada tipo e indicar sus atributos:

1. Tipo
2. Propietario
3. Contenedores o Soportes del Activo de Información
4. Custodio
5. Origen
6. Acceso al activo
7. Dependencias

1 - Recopilar Datos

ALTERNATIVA DE SOLUCION

IDENTIFICACIÓN DE ACTIVOS - Inventario

*Clasificamos un activo del Proceso de **Toma de exámenes en UTN***

ACTIVO: Acta de Examen

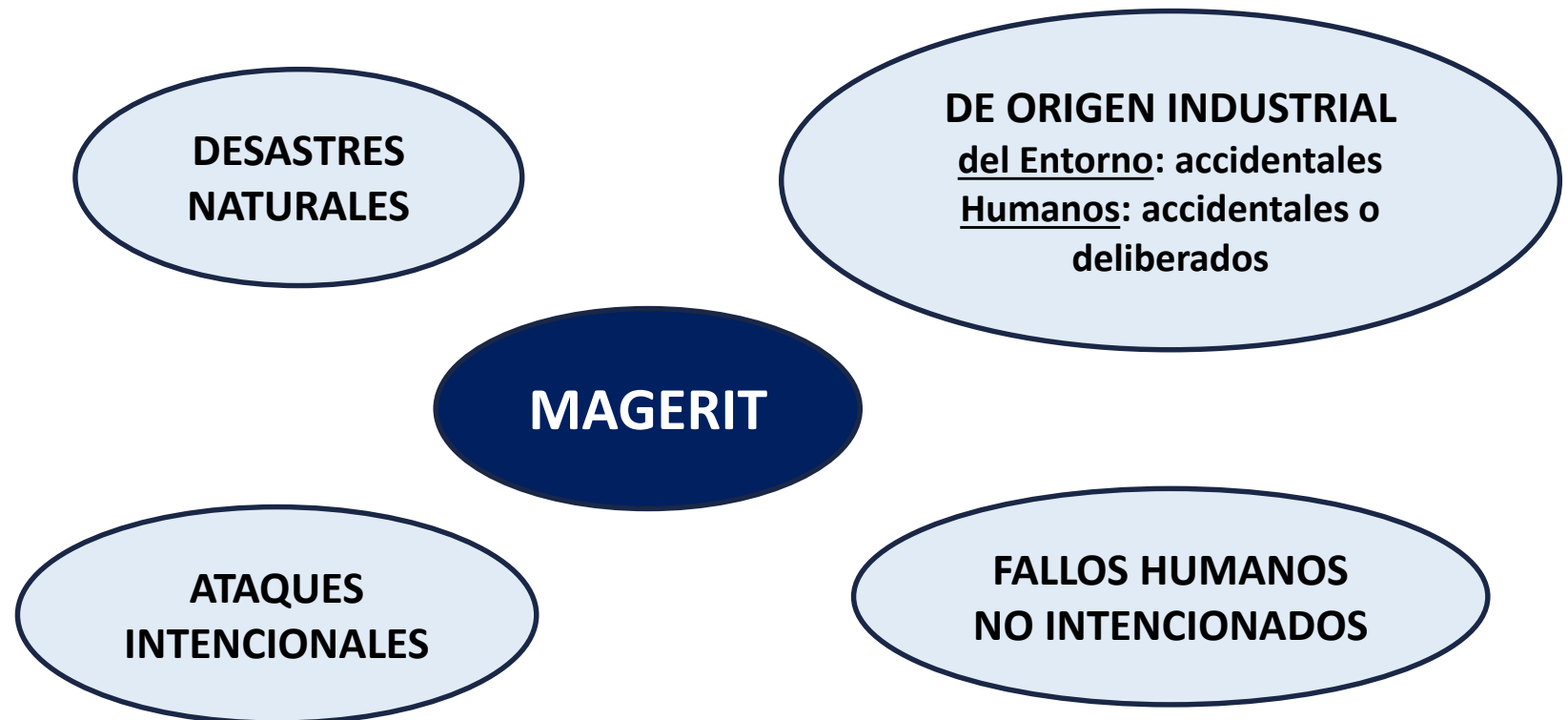
- **Tipo** → de Información
- **Propietario** → Jefe de Legajos y Actas
- **Contenedores** → BD Sysacad, carpeta
- **Custodio** → Bedel, Área Redes
- **Origen** → Administrativo de Legajos y Actas
- **Acceso al activo** → Reservado bedelía, reservado Legajos y Actas
- **Dependencias con otros activos** → de INST: oficina Bedelía, de INFO: credenciales acceso Sysacad, de INST: oficina Legajos y Actas

[Planilla Inventario de Activos](#)
[Toma Exámenes UTN](#)

El proceso de Gestión de Riesgos

1 - *Recopilar Datos*

IDENTIFICACIÓN DE AMENAZAS Y VULNERABILIDADES



El proceso de Gestión de Riesgos

1 - Recopilar Datos

IDENTIFICACIÓN DE AMENAZAS Y VULNERABILIDADES



El proceso de Gestión de Riesgos

1 - Recopilar Datos

TAXONOMÍAS PARA LA IDENTIFICACIÓN DE RIESGOS

Taxonomy of Operational Cyber Security Risks (SEI)

1. Acciones de las Personas	2. Fallas de Sistemas y Tecnología	3. Fallas de Procesos Internos	4. Eventos externos
1.1 Involuntarias	2.1 Hardware	3.1. Diseño de Procesos y Ejecución	4.1 Desastres
1.1.1 Equivocación (acción incorrecta)	2.1.1 Capacidad	3.1.1 Flujo de Procesos	4.1.1 Climatológicos
1.1.2 Error (x desconocimiento)	2.1.2 Rendimiento	3.1.2 Document. de Procesos	4.1.2 Incendios
1.1.3 Omisión (x apresuramiento)	2.1.3 Mantenimiento	3.1.3 Roles y responsabil.	4.1.3 Inundaciones
	2.1.4 Obsolescencia	3.1.4 Notificaciones y alertas	4.1.4 Terremotos
1.2 Deliberadas	2.2 Software	3.1.5 Flujo de Información	4.1.5 Disturbios
1.2.1 Fraude	2.2.1 Compatibilidad	3.1.6 Escalado de problemas	4.1.6 Pandemias
1.2.2 Sabotaje	2.2.2 Configuración	3.1.7 Acuerdo de Nivel de Serv.	4.2 Cuestiones Legales
1.2.3 Robo	2.2.3 Control de Cambios	3.1.8 Tarea fuera de control	4.2.1 Regulaciones
1.2.4 Vandalismo	2.2.4 Parámetros de Seguridad	3.2 Control de Procesos	4.2.2 Legislación
1.3 Inacción	2.2.5 Prácticas de Codificación	3.2.1 Monitorización del estado	4.2.3 Litigios
1.3.1 Habilidad	2.2.6 Testing	3.2.2 Métricas	4.3 Cuestiones del Negocio
1.3.2 Conocimiento	2.3 Sistemas	3.2.3 Revisiones Periódicas	4.3.1 Fallas del Suministro
1.3.3 Guía	2.3.1 Diseño	3.2.4 Dueño del Proceso	4.3.2 Condiciones del Mercado
1.3.4 Disponibilidad	2.3.2 Especificaciones	3.3 Procesos de Soporte	4.3.3 Condiciones Económicas
	2.3.3 Integración	3.3.1 Dotación del Personal	4.4 Dependencias con Servicios
	2.3.4 Complejidad	3.3.2 Recursos	4.4.1 Servicios Públicos
		3.3.3 Entrenamiento y desarr.	4.4.2 Servicios de Emergencia
		3.3.4 Adquisición	4.4.3 Combustible
			4.4.4 Transporte

Identificación del Riesgo

Actividad

La organización PINAIRES ha decidido encarar una serie de proyectos de adecuación de TI. Nos han asignado el siguiente proyecto:



PINAIRES
Alimentos para el mundo

<https://tinyurl.com/ASI-CTX-Pinares>

Transformación Digital: Incorporación de sensores de IOT en la línea de elaboración y envasado de galletitas.

TAREA: Identificar **un riesgo de TI** vinculado al proyecto, asociado a su funcionamiento en producción. **Describirlo y Clasificarlo según SEI.**



IDENTIFICACIÓN DE RIESGOS			
Id.			
Identificador	Legajo:	Apellido y Nombres:	
Especificación			
Clasificación			
Descripción ampliada del Contexto del Riesgo			

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

*“Un riesgo **NO** es un **PROBLEMA**....
El **PROBLEMA** es un **RIESGO**
que ha acontecido”*

Robert Charette



El proceso de Gestión de Riesgos

2 - *Analizar el Riesgo*

DEFINICIÓN

Riesgo

es la *probabilidad de que ocurra un evento* que pueda afectar los objetivos de la organización

ISO 9001

Un riesgo puede ser

- negativo (AMENAZA) o
- positivo (OPORTUNIDAD).

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Definiciones de riesgos con el concepto dual de resultados positivos o negativos

ISO 31000 / COBIT 2019

Riesgo es el *efecto de la incertidumbre sobre el logro de los objetivos*, donde *efecto* es un **desvío respecto a lo esperado**

PMI en el contexto de Proyectos

Los **objetivos** de la Gestión de los Riesgos del Proyecto son **aumentar la probabilidad e impacto de eventos positivos (oportunidades)**, y **disminuir la probabilidad e impacto de eventos adversos (amenazas)** para el proyecto

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Valoración del Riesgo

Los riesgos se pueden evaluar en términos de la combinación de:

Consecuencias de un **incidente o evento**
(efecto de amenazas / oportunidades explotando
las vulnerabilidades / fortalezas de los activos)



IMPACTO

Incertidumbre de que el **incidente o evento**
se produzca o no



PROBABILIDAD

El estado del riesgo, exposición o severidad se calcula como:

$$\text{SEVERIDAD} = \text{PROBABILIDAD} \times \text{IMPACTO}$$

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Valoración del Riesgo

La **SEVERIDAD** del riesgo puede evaluarse de dos formas:

- **Evaluación Cualitativa**

se calcula utilizando escalas de probabilidad e impacto

- **Impacto:** 0-Insignificante a 5-Severo

- **Probabilidad:** 0-Imposible, 1-Raro a 5-Casi seguro (>60%)

- **Evaluación Cuantitativa**

se calcula numéricamente

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Valoración del Riesgo - Evaluación **Cualitativa****Matriz de Riesgo**

Permite visualizar, cuantificar, transferir o mitigar los riesgos y tomar decisiones

Impacto
¿Qué tan severos serían los resultados si ocurriera el riesgo?

Probabilidad
¿Cuál es la probabilidad de que ocurra el riesgo?

	Insignificante 1	Menor 2	Significativo 3	Mayor 4	Severo 5
5 Casi seguro	Medio 5	Alto 10	Muy alto 15	Extremo 20	Extremo 25
4 Probable	Medio 4	Medio 8	Alto 12	Muy alto 16	Extremo 20
3 Moderado	Bajo 3	Medio 6	Medio 9	Alto 12	Muy alto 15
2 Poco probable	Muy bajo 2	Bajo 4	Medio 6	Medio 8	Alto 10
1 Raro	Muy bajo 1	Muy bajo 2	Bajo 3	Medio 4	Medio 5

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Valoración del Riesgo - Evaluación Cualitativa

Probabilidad

1. **RARO** - la probabilidad de que ocurra es casi nula
2. **POCO PROBABLE** - probabilidad baja, aunque puede presentarse
3. **MODERADO** – el riesgo puede materializarse en cualquier momento
4. **PROBABLE** – la materialización del riesgo es alta, suele presentarse
5. **CASI SEGURO** – muy alta probabilidad de ocurrencia

Impacto
¿Qué tan severos serían los resultados si ocurriera el riesgo?

	Insignificante 1	Menor 2	Significativo 3	Mayor 4	Severo 5
5 Casi seguro	Medio 5	Alto 10	Muy alto 15	Extremo 20	Extremo 25
4 Probable	Medio 4	Medio 8	Alto 12	Muy alto 16	Extremo 20
3 Moderado	Bajo 3	Medio 6	Medio 9	Alto 12	Muy alto 15
2 Poco probable	Muy bajo 2	Bajo 4	Medio 6	Medio 8	Alto 10
1 Raro	Muy bajo 1	Muy bajo 2	Bajo 3	Medio 4	Medio 5

Probabilidad
¿Cuál es la probabilidad de que ocurra el riesgo?

Impacto → Nivel de afectación que causaría en la empresa

1. **INSIGNIFICANTE** – No es problema para la organización
2. **MENOR** – la materialización del riesgo genera impacto mínimo
3. **SIGNIFICATIVO** – puede causar pérdida momentánea
4. **MAYOR** – genera retrasos importantes que afectan cumplimiento de objetivos
5. **SEVERO** – puede detener la operación de la empresa y hasta cierre.

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Valoración del Riesgo – Evaluación **Cuantitativa**

Para definir valor del **IMPACTO** podemos referirnos a:

- **valor** que el activo tiene para la organización
- **magnitud de la pérdida** que sufriría la misma si fuese afectado dicho activo

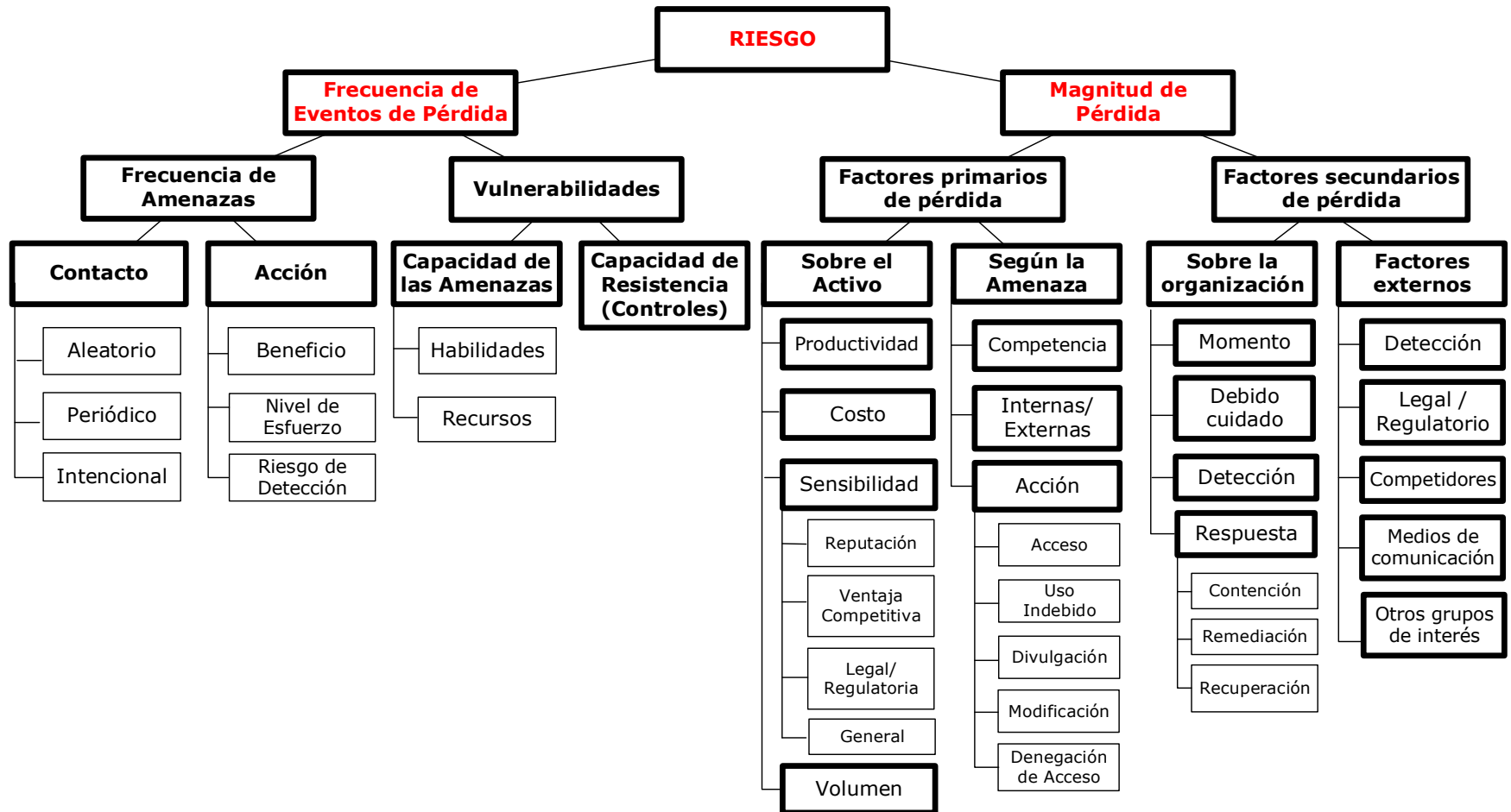
**Dimensiones
de Valoración**

- **Confidencialidad:** asociado a la información y derivado del marco regulador externo o criterios internos. Alta valoración cuando su revelación causara graves daños a la organización.
- **Disponibilidad:** en función al número de personas afectadas por falta de disponibilidad o por un funcionamiento irregular.
- **Integridad:** en función del daño de su alteración, voluntaria o intencionada

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

FAIR Valoración del Impacto y Probabilidad del Riesgo



El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

FAIR Valoración del Impacto y Probabilidad del Riesgo

Frecuencia
de Eventos de Pérdida

Número de veces que es probable que ocurra un evento de pérdida dentro de un período de tiempo definido.

Frecuencia de Amenaza

la cantidad probable de veces que una amenaza actúe (de forma exitosa o no) sobre el recurso.

Es afectada por

- **Frecuencia de Contacto**
cada cuánto un activo entra en contacto con una amenaza
- **Probabilidad de Acción**
probabilidad de que una amenaza actúe contra un activo si entra en contacto con él

Vulnerabilidad del recurso

es la probabilidad de que un amenaza se materialice en una pérdida de información.

Depende de

- **Capacidad de la Amenaza**
es el nivel de fuerza que puede aplicar la amenaza sobre el activo.
Por ejemplo, hay tipos de malware o ransomware más destructivos que otros.
- **Capacidad de Resistencia**
cuánta resistencia es capaz de ofrecer un activo frente a una amenaza.
Por ejemplo, un password de fortaleza fuerte no es lo mismo que el típico "123456".

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

FAIR Valoración del Impacto y Probabilidad del Riesgo

Magnitud
de la Pérdida

Son las pérdidas sufridas a raíz del evento, resultado del impacto exitoso del agente de amenaza en el activo

Pérdida Primaria

la que ocurre directamente como resultado de la acción de la amenaza sobre el activo.

Por ejemplo, en un ataque de denegación de servicio sobre la web de la empresa, la pérdida es la caída de la web y el perjudicado, la empresa.

componentes principales

- **Activos**
Además de las dimensiones ya establecidas, FAIR agrega elementos que permiten mejorar su valuación.
- **Amenazas**
Algo que sea capaz de actuar contra un activo de manera que pueda resultar en daño .

Pérdida Secundaria

la pérdida sufrida por el interesado principal debido a la reacción negativa de los interesados secundarios ante el evento de pérdida.

Por ejemplo, Si es la web de una empresa que da un servicio de CRM, los afectados serán los clientes del CRM

factores referidos a

- **la organización**
Las características de la organización pueden servir para atraer la atención de comunidades de amenazas, que pueden aumentar la frecuencia de los eventos.
- **el ambiente externo**
cuando el evento es detectado por una entidad externa.

El proceso de Gestión de Riesgos

*2 - Analizar el Riesgo***RIESGO INHERENTE**

La valorización del riesgo realizada nos permitirá establecer el **riesgo inherente** (*comúnmente mencionado solo como riesgo*).

Este es el riesgo que se presenta sin aplicar ninguna medida sobre las amenazas (u oportunidades), vulnerabilidades, impacto o probabilidad, es decir **sin aplicar ninguna estrategia para disminuir (o aumentar) su severidad**.

Análisis del Riesgo

Actividad

A partir del riesgo antes identificado para el Proyecto de Transformación Digital de PINAIRES



PINAIRES
Alimentos para el mundo

<https://tinyurl.com/ASI-CTX-Pinares>

TAREA: Identificar Activos y su dimensión de criticidad.

Calcular su severidad, indicando como llegaron a ese valor, usando FAIR

VALORACIÓN DEL RIESGO
ACTIVOS involucrados y dimensión de valor de su criticidad:
Descripción de Factores analizados para evaluar PROBABILIDAD:
Descripción de Factores analizados para evaluar IMPACTO:
VALORACIÓN DEL RIESGO: PROBABILIDAD = IMPACTO = SEVERIDAD =

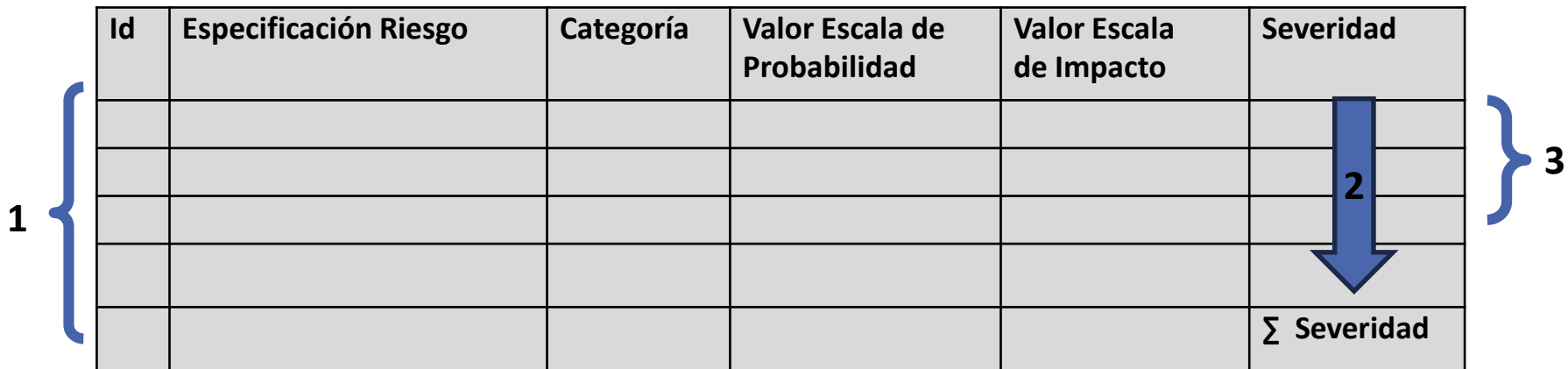
El proceso de Gestión de Riesgos

2 - Analizar el Riesgo

Priorización para el Tratamiento de Riesgos

Cómo hacerlo

1. Listamos los riesgos inherentes y aplicamos PARETO 80-20 (el 80% de la severidad está cubierta por en 20% de los riesgos)
2. Ordenamos la lista en forma decreciente por severidad
3. Seleccionamos los riesgos cuya suma de severidad sea el 80% de la Σ Severidad



Id	Especificación Riesgo	Categoría	Valor Escala de Probabilidad	Valor Escala de Impacto	Severidad
					Σ Severidad

Una vez establecidas las estrategias de tratamiento será necesario volver a **calcular su severidad** porque puede haber variado.

Este será el **riesgo RESIDUAL**, que será el riesgo que estamos dispuestos a aceptar.

El proceso de Gestión de Riesgos

*2 - Analizar el Riesgo***RIESGO RESIDUAL**

Comprende aquellos peligros que persisten una vez implementados todos los controles y medidas de prevención existentes respecto de los riesgos inherentes.

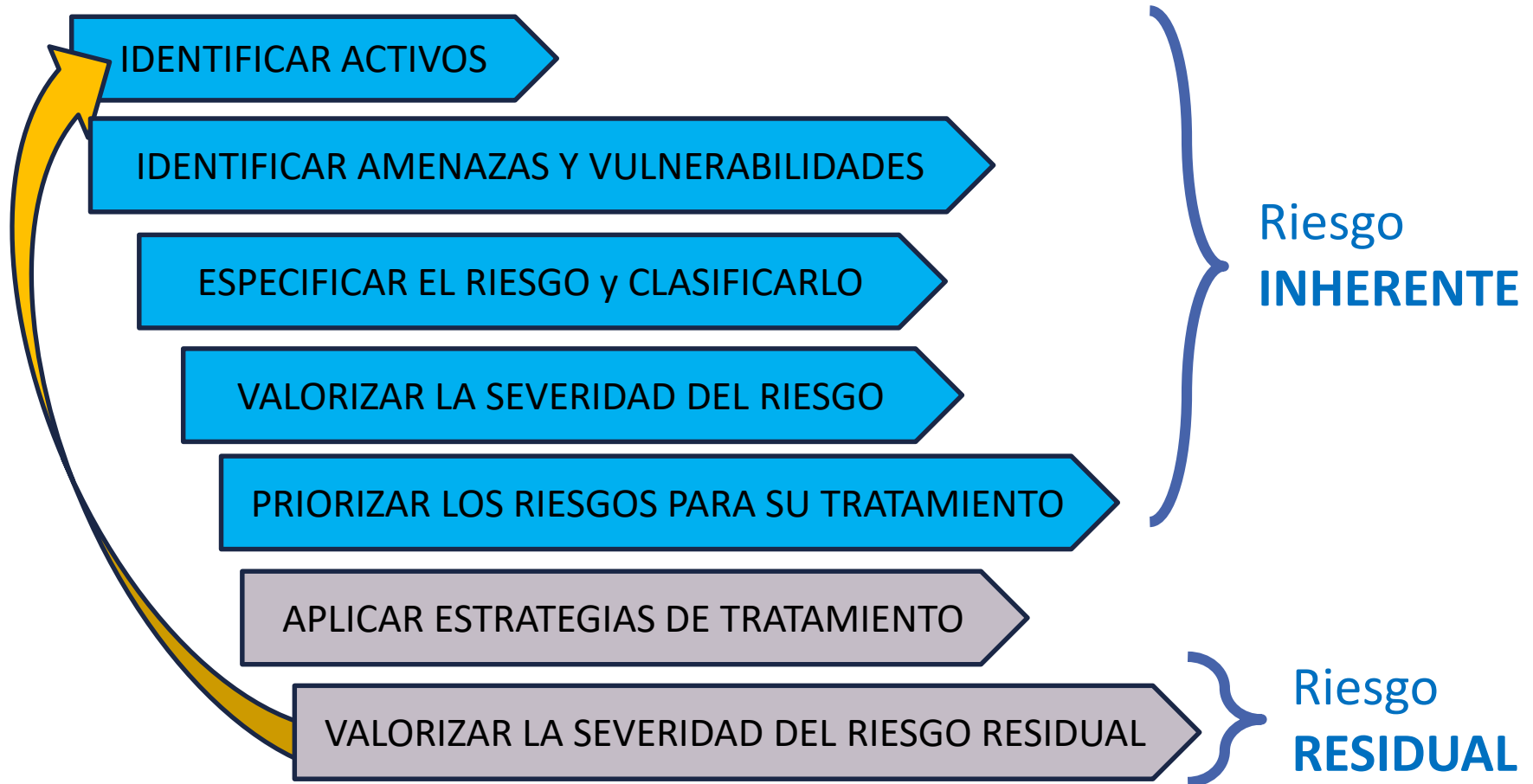
Aunque nunca podrá reducirse a cero, se puede trabajar sobre aquellas medidas que podrían tomarse para reducir su impacto.

Puede decirse, entonces, que, mientras que el **Riesgo inherente** es el existente al momento de no aplicar ningún tipo de acción para alterar su probabilidad o impacto de suceso, el **Riesgo residual** es el que persiste después de que se han implementado controles o medidas de mitigación para reducir el riesgo inherente.

*Por ejemplo, después de implementar medidas de seguridad en un automóvil, como cinturones de seguridad y airbags, aún existe un **riesgo residual de accidente**, pero la gravedad y la probabilidad del riesgo se han reducido significativamente.*

El proceso de Gestión de Riesgos

2 - Analizar el Riesgo



La especificación del riesgo no ha variado. Sólo su severidad.

El proceso de Gestión de Riesgos

3 – Responder al Riesgo

Actividades para responder a los riesgos

Incluyen **controles** de tipo:

- **Preventivos**
Reducen probabilidad o impacto del riesgo o eliminan sus causas.
Estrategias de tratamiento, en función al riesgo.
- **Detectivos**
Detectan riesgo una vez ocurrido, reducen impacto del riesgo.
Planes de Contingencia y continuidad del Negocio.
- **Correctivos**
Identifican y corrigen las causas del riesgo ocurrido.
Planes de Recuperación.

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Estrategias de Tratamiento de los riesgos

Estrategias:

Controles y acciones que deberemos establecer frente a la posible **materialización** del riesgo de forma tal que la **severidad** del riesgo se vea **disminuida**.

ISO 27002:2022

Tipo de Control: Preventivo

Dimensiones:

- Integridad
- Confidencialidad
- Disponibilidad

Conceptos de Ciberseguridad: Proteger

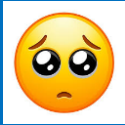


Fuente: www.ISO27000.es

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Estrategias de Tratamiento de los riesgos

**Riesgos NEGATIVOS**
(amenazas)

- **Evitar** No se acepta de esa forma.
- **Transferir** riesgo y su gestión a un tercero (Subcontratar, Asegurar)
- **Mitigar** hacer lo posible para minimizar ocurrencia (probabilidad) y consecuencias (impacto)
- **Aceptar:** Se aceptan las consecuencias de su posible ocurrencia.

**Riesgos POSITIVOS**
(oportunidades)

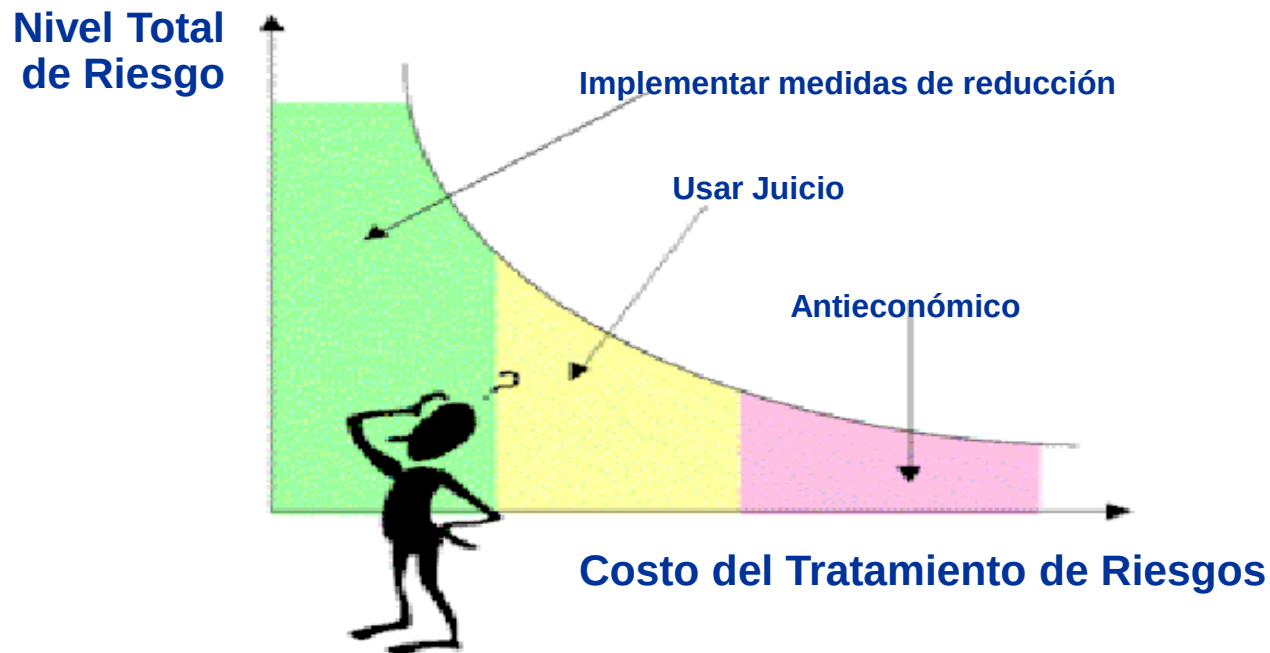
- **Explotar:** tratar que la oportunidad sea una realidad.
- **Compartir:** Transferir la oportunidad a un tercero mejor capacitado.
- **Mejorar:** Buscar maximizar ocurrencia (probabilidad) y consecuencias (impacto)
- **Aceptar:** Aceptar consecuencias de su posible ocurrencia.

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Costo de implementación

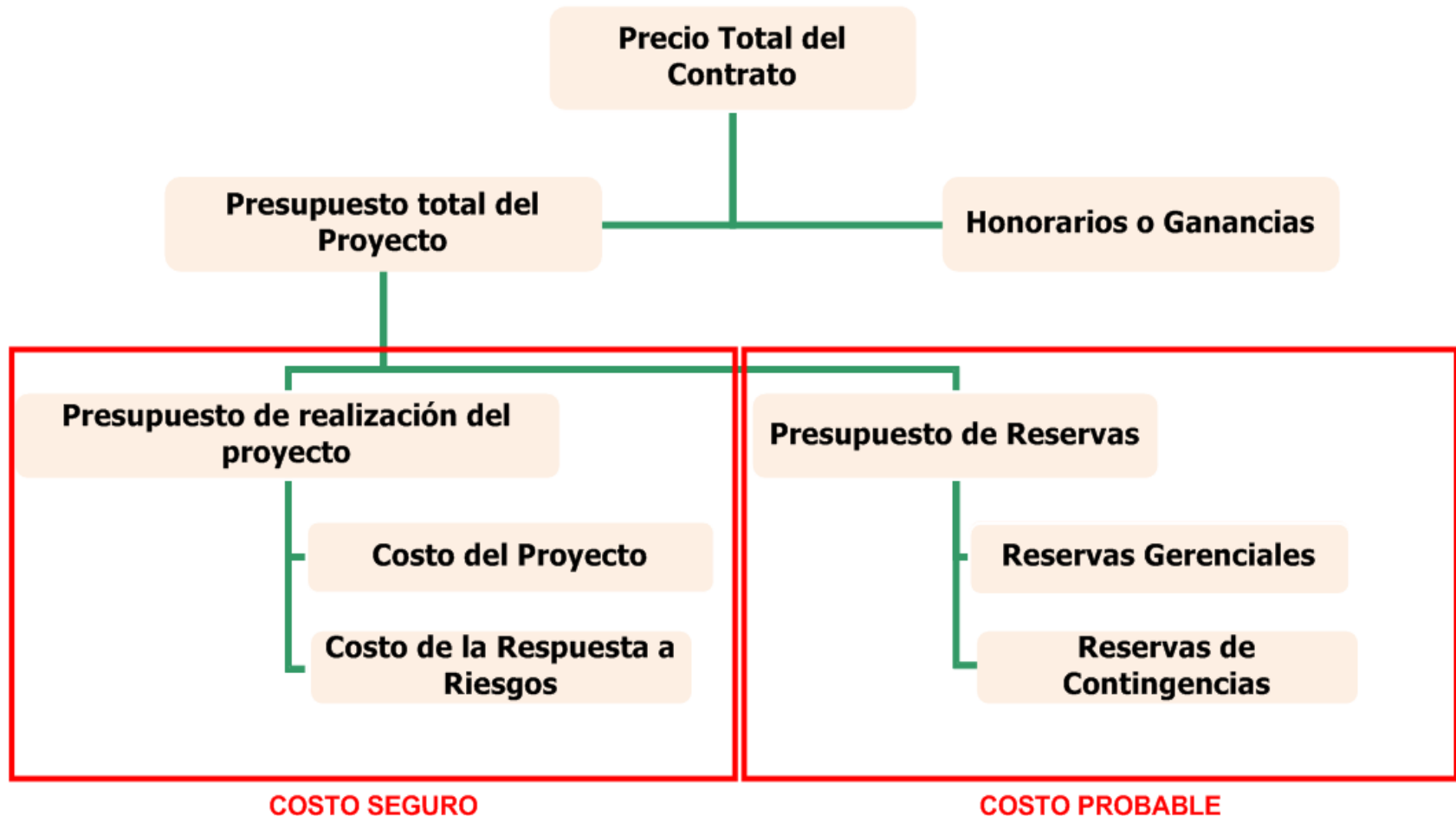
Deberemos balancear el **costo de implementación** de controles y acciones de tratamiento de los riesgos **contra** los **beneficios derivados** en función del nivel de riesgo



El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Estrategias de Tratamiento de los riesgos



El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Planes de Contingencia, Recuperación y Continuidad de Negocio

Identificados riesgos y su tratamiento se actuará sobre el

RIESGO RESIDUAL



Es el nivel de riesgo que la organización **está dispuesta a aceptar** y para el que deberán plantearse los **Planes de:**

- contingencia,  Indica procedimientos a ejecutar ante la eventual ocurrencia de un riesgo.
- recuperación y  Para restablecer rápidamente los servicios de la organización
- continuidad de negocio

Análisis del Riesgo

Actividad

A partir del riesgo antes identificado para el Proyecto de Transformación Digital de PINAIRES



PINAIRES
Alimentos para el mundo

<https://tinyurl.com/ASI-CTX-Pinares>

TAREA: Plantear estrategias para **Evitar, Transferir y Mitigar** el riesgo. Definir **controles**.

Calcular el **Riesgo Residual**

ESTRATEGIAS	EVITAR
	TRANSFERIR
	MITIGAR
CONTROLES	
RIESGO RESIDUAL	

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Planes de Contingencia, Recuperación y Continuidad de Negocio

Los planes deben ***prever***:

- ✓ **Actividades de monitoreo** de la materialización de un riesgo (atento a alarmas o indicadores)
- ✓ **Acciones** a poner en práctica cuando **ocurra** el riesgo
- ✓ **Formación del equipo** encargado de su ejecución
- ✓ Entrenamiento con **simulacros**

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Planes de Contingencia, Recuperación y Continuidad de Negocio

A partir de la **detección de la materialización** del riesgo los planes deberán indicar la forma de:

1. **Evaluar los daños**
2. **Priorizar** las actividades del plan de acción
3. **Ejecutar** las actividades
4. **Evaluar los resultados**
5. **Restablecer** las operaciones

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Plan de **Contingencia**

Especifica los procedimientos que se ejecutarán ante la eventual ocurrencia de un riesgo que hagan desviar a la organización de sus planes originales.

Por ejemplo, qué medidas se tomarán si el servicio de software se cae durante más de tres horas.

Si se ejecuta correctamente, puede mitigar el riesgo y ayudar a volver a la normalidad lo más rápido posible.

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Plan de **Recuperación**

Permite **restablecer rápidamente** los servicios de la organización.

Su objetivo principal es minimizar la interrupción del normal funcionamiento y el impacto del corte y lograr que las aplicaciones de misión crítica vuelvan a funcionar en el menor tiempo posible para que toda la organización y sus trabajadores retomen cuanto antes sus actividades.

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Plan de **Continuidad** de Negocio

Especifica **cómo se realizarán las actividades críticas** del negocio para las cuales puede **no contarse con los activos normalmente utilizados** en las mismas.

Es el conjunto de prácticas que una organización establece para mantenerse operativa durante una situación de contingencia o bien tras un periodo de suspensión de actividades.

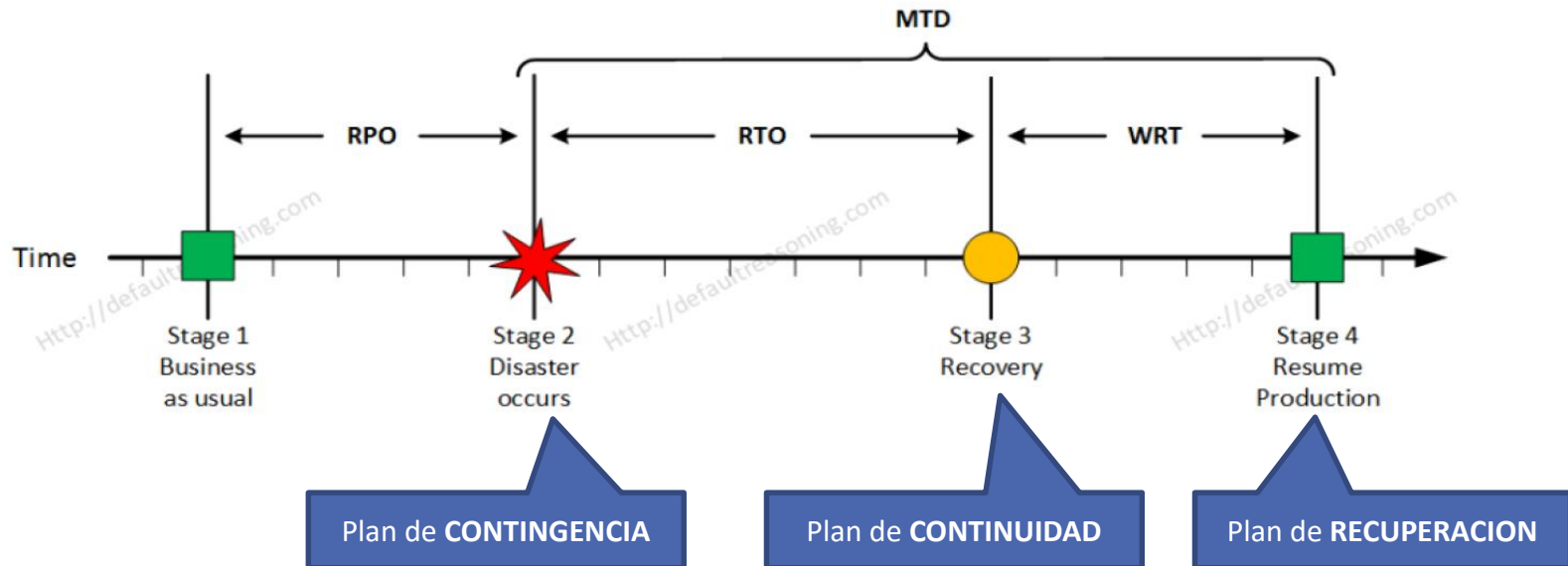
Tiene como fin recuperar la capacidad productiva de la organización y, al mismo tiempo, asegurar el cumplimiento de estándares tras la interrupción de actividades.

Se ejecuta en el tiempo que media entre cuando sucede la contingencia y el momento en que se recuperan los servicios.

El proceso de Gestión de Riesgos

3 – *Responder al Riesgo*

Continuidad del Negocio



RPO (Recovery Point Objective): determina el objetivo de posible pérdida máxima de datos introducidos desde el último backup, hasta la caída del sistema

RTO (Recovery Time Objective): determina el tiempo en que se puede recuperar el sistema

WRT (Work Recovery time): El tiempo máximo necesario para verificar el sistema, la integridad de los datos, entre otros. *Por ejemplo: chequear información faltante, chequear bases de datos, logs, levantar servicios, etc.*

Análisis del Riesgo

Actividad

A partir del riesgo antes identificado para el Proyecto de Transformación Digital de PINAIRES



PINAIRES
Alimentos para el mundo

<https://tinyurl.com/ASI-CTX-Pinares>

TAREA: Identificar disparadores de la ocurrencia del riesgo y plantear Planes de **Contingencia**, Recuperación y Continuidad de Negocio

Disparadores	
Contingencia	
Recuperación	
Continuidad de Negocio	

